

ENTERPRISE CYBERSECURITY RISK ASSESSMENT

BlueWave Retail Solutions

GRC Portfolio Project

Prepared by

Dhriti Pandya

BS Applied Computer Science — Cybersecurity

University of South Carolina Aiken

August 2026

Enterprise Cybersecurity Risk Assessment

1. EXECUTIVE SUMMARY

This cybersecurity risk assessment evaluates the information technology environment of BlueWave Retail Solutions, a fictional mid-sized retail and e-commerce organization with approximately 250 employees operating across six locations. The assessment focuses on key business and technology assets, including customer databases, Microsoft 365, Active Directory, employee laptops, POS systems, corporate Wi-Fi, the public website, backup systems, the HR Information System, and the Financial Management System.

The assessment identified cybersecurity threats and vulnerabilities affecting these assets and evaluated the associated risks using a 5×5 Likelihood and Impact methodology. The resulting risk register identified risks ranging from Medium to Critical, with several high-priority risks requiring additional security measures.

Recommended risk treatments primarily focus on mitigation through controls such as multi-factor authentication, role-based access control, encryption, patch management, network segmentation, security monitoring, and offline or immutable backups. The assessment also maps key security activities to the five functions of the NIST Cybersecurity Framework: Identify, Protect, Detect, Respond, and Recover.

The assessment provides BlueWave with a structured approach for prioritizing cybersecurity risks, strengthening security controls, and improving the organization's overall cybersecurity posture.

2. COMPANY OVERVIEW

- **Company size:**
BlueWave Retail Solutions has approximately 250 employees.
- **Location:**
The company operates across six locations.

- **Business model:**

It is a retail and e-commerce company that sells consumer electronics through physical stores and an online platform.

- **Technology environment:**

- Microsoft 365
- Active Directory
- Employee laptops
- Cloud-based customer database
- POS systems
- Corporate Wi-Fi
- Public-facing website
- Backup Systems
- HR Information System
- Financial Management System

- **Why cybersecurity matters:**

The company handles customer information and payment-related data, so cybersecurity is an important business concern.

3. ASSESSMENT SCOPE

Included

We're assessing:

- Microsoft 365
- Active Directory

- Employee laptops
- Customer database
- POS systems
- Corporate Wi-Fi
- Public website
- Backup Systems
- HR Information System
- Financial Management System

Not included

- Third-party vendors
- Employees' personal devices
- Physical building security
- Manufacturing systems

4. BUSINESS OBJECTIVES

BlueWave's main security objectives are:

Objective 1 — Protect customer information

Prevent unauthorized access, modification, or disclosure of customer data.

Objective 2 — Maintain business operations

Keep POS systems, websites, emails, and other critical systems available.

Objective 3 — Reduce cybersecurity risk

Identify important risks and implement appropriate controls.

Objective 4 — Support compliance

Maintain security practices that support applicable legal, contractual, and industry requirements.

Objective 5 — Protect company reputation

Prevent cybersecurity incidents that could damage customer trust or the company's reputation.

5. ASSET INVENTORY

ID	Asset	Owner	Criticality	Why is it important?
A001	Customer Database	IT	High	Contains customer information
A002	Microsoft 365	IT	High	Email, files, and collaboration
A003	Active Directory	IT	High	Manages user identities and access
A004	Employee Laptops	IT	Medium	Used for daily business operations
A005	POS Systems	Retail Operations	High	Process retail transactions
A006	Corporate Wi-Fi	IT	Medium	Provides network connectivity
A007	Public Website	IT / Marketing	Medium	Supports online sales and customer interaction
A008	Backup Systems	IT	High	Used to restore important business data and systems after data loss or a cyber incident.

A009	HR Information System	HR	High	Stores sensitive employee information and supports important HR operations.
A010	Financial Management System	Finance	High	Stores financial information and supports critical financial operations.

6. THREAT IDENTIFICATION

ID	Asset	Threat	Threat Category
T001	Customer Database	Unauthorized access/ Insider data theft	Human/Cyber
T002	Microsoft 365	Phishing	Human/Cyber
T003	Active Directory	Credential compromise	Human/Cyber
T004	Employee Laptops	Device theft	Physical
T005	POS Systems	Malware	Human/Cyber
T006	Corporate Wi-Fi	Unauthorized network access	Human/Cyber
T007	Public Website	DDoS attack	Human/Cyber
T008	Backup Systems	Ransomware	Human/Cyber
T009	HR Information System	Unauthorized access	Human/Cyber
T010	Financial Management System	Financial fraud	Human/Cyber

7. VULNERABILITY ASSESSMENT

ID	Asset	Threat	Vulnerability
V001	Customer Database	Unauthorized access	Excessive user permissions
V002	Microsoft 365	Phishing	Insufficient phishing awareness / inconsistent MFA

V003	Active Directory	Credential compromise	Weak password practices
V004	Employee Laptops	Device theft	Lack of full-disk encryption
V005	POS Systems	Malware	Outdated POS software
V006	Corporate Wi-Fi	Unauthorized network access	Weak wireless security configuration
V007	Public Website	DDoS attack	Lack of adequate DDoS protection
V008	Backup Systems	Ransomware	Backups connected to production environment
V009	HR Information System	Unauthorized access	Excessive employee permissions
V010	Financial Management System	Financial fraud	Insufficient segregation of duties

8. RISK ASSESSMENT METHODOLOGY

Risk will be evaluated using a qualitative scoring methodology based on Likelihood and Impact. Each factor will be assigned a score from 1 to 5. The overall Risk Score will be calculated by multiplying Likelihood by Impact. The resulting score will be categorized as Low, Medium, High, or Critical.

Risk Scoring Methodology

BlueWave's cybersecurity risks will be evaluated using Likelihood and Impact. Each factor will be assigned a score from 1 to 5. The overall risk score will be calculated by multiplying the Likelihood score by the Impact score.

Likelihood Scale

Score	Rating	Description
1	Rare	Very unlikely to occur
2	Unlikely	Unlikely to occur

3	Possible	Could occur
4	Likely	Likely to occur
5	Almost Certain	Expected to occur

Impact Scale

Score	Rating	Description
1	Insignificant	Minimal effect on the organization
2	Minor	Limited operational or financial effect
3	Moderate	Noticeable effect requiring management attention
4	Major	Significant operational, financial, or reputational effect
5	Severe	Serious effect that could significantly disrupt the organization

Risk Rating

Risk Score = Likelihood × Impact

Score	Risk Level
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Likelihood ↓ / Impact →	1	2	3	4	5
5 — Almost Certain	5	10	15	20	25
4 — Likely	4	8	12	16	20
3 — Possible	3	6	9	12	15
2 — Unlikely	2	4	6	8	10

1 — Rare	1	2	3	4	5
-----------------	---	---	---	---	---

9. RISK REGISTER

Residual risk represents the estimated level of risk remaining after the recommended controls are implemented and operating effectively. Because this assessment is based on a fictional organization and does not include control-testing evidence, residual-risk ratings are estimates intended to support prioritization and demonstrate the risk-treatment process.

ID	Asset	Inherent Risk	Risk Owner	Primary Control	Residual Risk	Priority
R001	Customer Database	15 — High	IT	RBAC + access reviews	L2 × I4 = 8 — Medium	High
R002	Microsoft 365	16 — High	IT	MFA + phishing training + email filtering	L2 × I3 = 6 — Medium	High
R003	Active Directory	15 — High	IT	Strong password policy + MFA + privileged access controls	L1 × I4 = 4 — Low	High
R004	Employee Laptops	12 — High	IT	Full-disk encryption + remote device management	L4 × I1 = 4 — Low	Medium
R005	POS Systems	15 — High	Retail Operations	Endpoint protection + patching + network segmentation	L2 × I3 = 6 — Medium	High
R006	Corporate Wi-Fi	12 — High	IT	Strong wireless authentication +	L2 × I2 = 4 — Low	Medium

				network segmentation		
R007	Public Website	9 — Medium	IT / Marketing	DDoS protection + availability monitoring	L2 × I2 = 4 — Low	Medium
R008	Backup Systems	20 — Critical	IT	Offline/immutable backups + restoration testing	L4 × I2 = 8 — Medium	Critical
R009	HR Information System	15 — High	HR / IT	RBAC + access reviews + audit logging	L2 × I4 = 8 — Medium	High
R010	Financial Management System	15 — High	Finance / IT	Segregation of duties + approval workflows + audit logging	L1 × I4 = 4 — Low	High

Note on residual risk methodology: Each control's effect on Likelihood and Impact was estimated individually rather than applying a uniform reduction. Controls that primarily prevent an attacker from acting (e.g., MFA, segregation of duties, privileged access controls) reduce Likelihood more heavily. Controls that limit the consequences of an incident once it occurs (e.g., full-disk encryption, offline backups) reduce Impact more heavily, even when Likelihood remains largely unchanged.

R008 — Backup Systems (Critical): This is the only risk rated Critical and warrants closer attention. Because backups were connected to the production environment, a successful ransomware attack could encrypt both live systems and their backups simultaneously, removing BlueWave's ability to recover without paying a ransom. This makes backups a single point of failure for the entire recovery process, not just another IT asset. Moving to offline or immutable backups does not reduce the likelihood that ransomware reaches the environment that risk is addressed separately through endpoint and network controls but it substantially reduces the impact by preserving a clean, unencrypted copy of business data that can be restored independently of the compromised systems. This is why the residual Impact score drops sharply (5 to 2) while the residual Likelihood stays unchanged (4).

10. SECURITY CONTROLS

ID	Risk	Recommended Control	Control Type	Purpose
C001	Customer Database — Unauthorized access	Role-Based Access Control (RBAC) + periodic access reviews	Preventive / Detective	Limit access to authorized users and identify inappropriate permissions
C002	Microsoft 365 — Phishing	MFA + phishing awareness training + email filtering	Preventive	Reduce successful phishing and account compromise
C003	Active Directory — Credential compromise	Strong password policy + MFA + privileged account controls	Preventive	Reduce credential compromise and unauthorized access
C004	Employee Laptops — Device theft	Full-disk encryption + remote device management	Preventive	Protect information if a device is lost or stolen
C005	POS Systems — Malware	Endpoint protection + patch management + network segmentation	Preventive / Detective	Reduce malware infection and limit its spread
C006	Corporate Wi-Fi — Unauthorized access	WPA3/strong wireless authentication + network segmentation	Preventive	Prevent unauthorized network access and isolate sensitive systems
C007	Public Website — DDoS attack	DDoS protection + availability monitoring	Preventive / Detective	Reduce service disruption and detect availability issues
C008	Backup Systems — Ransomware	Offline/immutable backups + regular backup testing	Preventive / Corrective	Protect backups and support recovery after ransomware

BlueWave Retail Solutions | Enterprise Cybersecurity Risk Assessment

C009	HR Information System — Unauthorized access	RBAC + periodic access reviews + audit logging	Preventive / Detective	Restrict sensitive HR data and monitor access
C010	Financial Management System — Financial fraud	Segregation of duties + approval workflows + audit logging	Preventive / Detective	Reduce fraudulent activity and provide accountability

Control	Expected Effectiveness
MFA	High
RBAC and access reviews	High
Encryption	High
Patch management	High
Network segmentation	High
DDoS protection	Medium–High
Offline/immutable backups	High
Audit logging	Medium–High
Security awareness training	Medium
Segregation of duties	High

11. RISK TREATMENT RECOMMENDATIONS

ID	Risk	Recommended Treatment	Recommendation
R001	Customer Database — Unauthorized access	Mitigate	Implement RBAC and conduct periodic access reviews.
R002	Microsoft 365 — Phishing	Mitigate	Enforce MFA, improve email filtering, and provide phishing awareness training.
R003	Active Directory — Credential compromise	Mitigate	Strengthen password requirements, implement MFA, and restrict privileged accounts.
R004	Employee Laptops — Device theft	Mitigate	Enable full-disk encryption and centralized remote device management.
R005	POS Systems — Malware	Mitigate	Implement endpoint protection, timely patching, and network segmentation.
R006	Corporate Wi-Fi — Unauthorized access	Mitigate	Strengthen wireless authentication and segment the network.
R007	Public Website — DDoS attack	Mitigate	Implement DDoS protection and continuous availability monitoring.
R008	Backup Systems — Ransomware	Mitigate	Maintain offline/immutable backups and regularly test restoration procedures.
R009	HR Information System — Unauthorized access	Mitigate	Implement RBAC, access reviews, and audit logging.
R010	Financial Management System — Financial fraud	Mitigate	Implement segregation of duties, approval workflows, and audit logging.

12. NIST CSF MAPPING

NIST CSF Function	BlueWave Activities
Identify	Asset inventory, business objectives, assessment scope, threat and vulnerability identification, risk assessment, and risk register
Protect	MFA, RBAC, encryption, patch management, network segmentation, security awareness training, and access controls
Detect	Audit logging, security monitoring, availability monitoring, and periodic access reviews
Respond	Incident response procedures, incident containment, escalation, and stakeholder communication
Recover	Offline/immutable backups, backup restoration testing, system recovery procedures, and restoration of critical business operations

13. CONCLUSION

The cybersecurity risk assessment demonstrates the importance of identifying and prioritizing risks based on their potential likelihood and impact on BlueWave Retail Solutions. The assessment identified risks affecting critical business assets and provided recommended controls and treatment strategies to reduce those risks.

The recommended security controls focus on protecting sensitive information, maintaining system availability, restricting unauthorized access, detecting suspicious activity, and supporting recovery following cybersecurity incidents.

BlueWave should periodically review its risk register, reassess existing controls, and update its cybersecurity practices as the organization's technology, threats, and business requirements change. Continued monitoring and risk management will help the organization maintain a stronger and more resilient cybersecurity posture.